

THREAT ADVISORY

Two actively exploited vulnerabilities affect multiple VMware products

TA2022093

Threat Level

RED

Publish Date – April 18, 2022

Multiple vulnerabilities have been discovered in VMware products. Two of these have been exploited in the wild.

The first zero-day vulnerability, CVE-2022-22954, is a server-side template injection flaw. An attacker could exploit this bug to gain network access and remotely execute code in order to deliver cryptominers.

Several Proof of Concepts (PoCs) of this issue indicate that it could be weaponized by ransomwares/ threat actor groups soon.

The second zero-day vulnerability, CVE-2022-22960 exists due to improper permissions in support scripts. An attacker could exploit this issue to escalate privileges to root on vulnerable servers.

Organizations are advised the patch all these vulnerabilities as soon as possible to avoid exploitation.

Potential MITRE ATT&CK TTPs are:

TA0042: Resource Development

TA0001: Initial Access

TA0004: Privilege Escalation

T1588: Obtain Capabilities

T1588.006: Obtain Capabilities: Vulnerabilities

T1190: Exploit Public-Facing Application

T1548: Abuse Elevation Control Mechanism

T1068: Exploitation for Privilege Escalation

Vulnerability Details

CVE ID	Affected Products	Affected CPE	Vulnerability Name	CWE ID
CVE-2022-22954*	VMware Workspace ONE Access versions 20.10.0.0 - 21.08.0.1; vRealize Suite Lifecycle Manager versions 8.0 - 8.4.1 Patch 2; VMware Cloud Foundation versions 4.0 - 4.3.1.1; VMware Identity Manager versions 3.3.3 - 3.3.6	cpe:2.3:a:vmware:vmware_workspace_one_access:*:*:*:*:*:* cpe:2.3:a:vmware:vrealize_suite_lifecycle_manager:*:*:*:*:*:* cpe:2.3:a:vmware:cloud_foundation:*:*:*:*:*:* cpe:2.3:a:vmware:identity_manager:*:*:*:*:*:*	Server-side Template Injection Remote Code Execution Vulnerability	CWE-94
CVE-2022-22960*			Local Privilege Escalation Vulnerability	CWE-269
CVE-2022-22957			JDBC Injection Remote Code Execution Vulnerabilities	CWE-502
CVE-2022-22958			JDBC Injection Remote Code Execution Vulnerabilities	CWE-502
CVE-2022-22959			Cross Site Request Forgery Vulnerability	CWE-352
CVE-2022-22961			Information Disclosure Vulnerability	CWE-200



THREAT ADVISORY

CVE ID	Affected Products	Affected CPE	Vulnerability Name	CWE ID
CVE-2022-22955	VMware Workspace ONE Access versions 21.08.0.1, 21.08.0.0, 20.10.0.1, 20.10.0.0	cpe:2.3:a:vmware:vmware_workspace_one_access:*:*:*:*:*:*.*	OAuth2 ACS Authentication Bypass Vulnerabilities	CWE-287
CVE-2022-22956				CWE-287

Patch Links

<https://kb.vmware.com/s/article/88099>

References

<https://www.vmware.com/security/advisories/VMSA-2022-0011.html>